

Stack 06 SOP preflight: consent and recovery check

Reviewer: Codex /root. Completed UTC: 2026-09-24T21:26:08.266534+00:00.

Identity and result

PR #859 head efdeb678bc33c616cf8048fb5773548f0da96fa7; immediate accepted Stack 05 base 5c3f2d927f56a8646178d00c0abc9ed01c427393. Live identities rechecked. Firmware worktree is clean. Exact-head CI 35982066194 remains successful. No implementation, dependency, build or workflow changes occurred after that run.

Local SOP preflight passes. No new confirmed in-scope firmware defect was found. No Copilot request was issued. This is a focused continuation of the consolidated local audit, not a claim that every prior check was executed again.

SOP passes and evidence

Identity/preservation: same immutable base/head and 52-path diff as the consolidated audit. Existing 506 predecessor test declarations and all 44 added test executions remain applicable; prior assertion-diff review is carried forward. Current git diff --check passes. No deleted protection or new source change requires another replay review.

Consumer compatibility: the CoinTable 24-entry restoration and full 10/24-entry and BTC two-entry wire checks remain applicable. The pinned host source comparison and 1,064 evidence hashes from the preceding audit are retained for the unchanged files. Physical transport behavior remains outside emulator evidence.

Security and equivalent inputs: re-read liquidity classifiers, the signing dispatcher, every specialized confirmation return and abort path. The earlier evidence covered malformed shapes, a first-screen cancellation and three legacy host vectors. It did not demonstrate refusal at every later liquidity screen followed by a successful retry. This pass closes that specific gap through actual host signing calls.

Test execution/skips: two new supplemental host tests execute without capability skips, using the current full emulator and pinned python-keepkey sources. Bitcoin-only excludes these Ethereum handlers; prior full/BTC validation remains unchanged. Broad-run skip totals are not rewritten or counted as newly executed tests.

Findings/artifacts/status: the previous SOP and stale-ledger findings remain dispositioned. The latest Copilot review remains historical on ff956077f, with its CoinTable concern repaired on the current head. This local pass does not relabel it a clean current-head review. The new raw runner, tests, XML/log and hashes are committed with this source and PDF on the separate documentation branch.

New falsification checks

Allowed behavior: a known mainnet DAI liquidity transaction to this wallet, or finite approval for its known DAI/WETH pair, can sign through the specialized review with AdvancedMode left disabled. Expected confirmation counts, derived from the source contract, are add 7, remove 6, approval 3, including final fee confirmation. All three valid flows produce signature components after exactly those counts.

Forbidden behavior: pressing No at any specialized or final fee screen must not yield a signature or leave a signing stream that corrupts the next attempt. For each of the seven add, six remove and three finite-approval confirmation positions, the test rejects that position, requires Failure_ActionCancelled immediately, requires exactly that many ButtonRequests, then retries the same operation with all confirmations accepted and checks successful completion with the expected screen count.

Result: 2 pytest tests passed, zero failures/skips. Their loops exercise 35 signing attempts: three positive flows, 16 rejected attempts, and 16 successful retries. Native-value/split/trailing unlimited-approval refusals,

key cleanup negative controls, metadata additive-screen checks, storage migration and workflow deadline checks retain their earlier evidence because the implementation is unchanged.

Limits: these tests prove consent control flow and usable retries. They count ButtonRequests; they do not OCR or independently verify the contents of every displayed pixel. Existing display-format and OLED evidence remains separate. Signature-component shape here is not an independent cryptographic oracle; the preceding unchanged legacy liquidity host module includes a fixed-signature vector. No physical-device or complete release-assembly acceptance follows.

Finish and evidence validity

No source remediation was required. The separate documentation commit changes no firmware, test registration, dependency pin or CI configuration; it adds supplemental reproducible audit tests and evidence only. Existing exact-head CI remains supporting execution on the unchanged firmware head. A duplicate full matrix would add no changed-source coverage, so none was dispatched.

The complete source review, historical finding dispositions, exact path inventory and earlier falsification results are in 715-06-final-local-review-20260924.md/PDF. This receipt supplements that audit with the newly executed consent cases. Physical USB/OLED/buttons, signed-device upgrade, older predecessor propagation into the assembled release and release promotion remain separate gates. Paid review remains an explicit later decision.